Systeme de Controle d'Acces

Banque Internationale

Auteurs : Achraf Hasnaoui
Mohamed Aziz Foudhaili

Module : Securite des systemes d'information

Modeles : RBAC, ABAC, BLP, Biba, Chinese Wall

Date : May 2, 2026

Document pedagogique — usage interne

0. Contents

1 Introduction **2**

2 Acteurs et operations **2**
2.1 Acteurs du systeme . . . 2
2.2 Operations metier principales . . . 2

3 Modeles de controle d'acces **3**
3.1 RBAC — Role-Based Access Control . . . 3
3.2 ABAC — Attribute-Based Access Control . . . 3
3.3 BLP — Bell-LaPadula (confidentialite) . . . 3
3.4 Biba — Modele d'integrite . . . 4
3.5 Chinese Wall — Brewer-Nash (conflits d'interet) . . . 4

4 Architecture en couches **4**

5 Niveaux de securite **5**

6 Division en equipes et effectifs **5**
6.1 Relation clientele — 120 agents (24%) . . . 5
6.2 Back-office — 80 agents (16%) . . . 5
6.3 Gestion de patrimoine — 60 conseillers (12%) . . . 6
6.4 Risque — 40 analystes (8%) . . . 6
6.5 Conformite / AML — 35 agents (7%) . . . 6
6.6 Audit interne — 20 auditeurs (4%) . . . 7
6.7 Juridique — 20 juristes (4%) . . . 7
6.8 Cadres commerciaux — 25 cadres (5%) . . . 8
6.9 Experts regionaux temporaires — pool de 10 . . . 8
6.10 Recapitulatif des effectifs . . . 9

7 Regles transverses **9**

8 Conclusion **9**

1. Introduction

Une banque internationale doit concilier deux exigences opposees : laisser chaque equipe travailler efficacement, et empecher tout acces non autorise aux donnees sensibles.

Pour y repondre, le systeme repose sur une **architecture en couches** combinant cinq modeles complementaires :

- **RBAC** — gestion des roles et heritages de permissions
- **ABAC** — filtrage contextuel (portefeuille, pays, duree)
- **BLP** — protection de la confidentialite (niveau critique)
- **Biba** — protection de l'integrite des donnees
- **Chinese Wall** — prevention des conflits d'interet

Chaque modele couvre une dimension differente. Ensemble, ils forment un dispositif complet et conforme aux exigences GAFI, ACPR et Bale III/IV.

2. Acteurs et operations

2.1 Acteurs du systeme

Acteur	Role	Niveau d'acces
Employe back-office	Traitement des operations et corrections administratives	N1 – N2
Conseiller patrimoine	Consultation des portefeuilles clients assignes	N2 – N3
Analyste risques	Analyse strategique du portefeuille global	N3
Equipe conformite / AML	Alertes fraude, sanctions, blanchiment	N3 – N4
Audit interne	Investigations transverses et controle des habilitations	N2 – N4
Equipe juridique	Echanges reglementaires, validation juridique	N3 – N4
Cadres commerciaux	Pilotage commercial, acces aux KPIs agreges	N2
Expert regional temp.	Investigation ponctuelle, acces borne dans le temps	Variable

Table 1: Acteurs et niveaux d'acces

2.2 Operations metier principales

Operation	Acteurs autorises	Controle requis
Consultation donnees clients	RC, GP, BO	RBAC + filtre ABAC
Traitement d'operations bancaires	BO, RC	Double validation >50k EUR
Consultation portefeuilles detailles	GP, Risques	Filtre ABAC portefeuille
Analyse de risque strategique	Analyste risques	Lecture seule
Gestion KYC avancee	Conformite	MFA + double validation
Traitement alertes fraude/sanctions	Conformite / AML	Isolation + MFA
Investigations internes	Audit, Juridique	Acces borne dans le temps
Echanges avec autorites	Juridique	Journalisation renforcee

Table 2: Operations et controles associes

3. Modeles de controle d'acces

3.1 RBAC — Role-Based Access Control

Principe. Les permissions sont attachees au role, et l'utilisateur herite des droits de son role organisationnel.

Pourquoi ce modele est necessaire. La banque dispose de roles metier bien definis (conseiller, analyste, auditeur...). RBAC permet de les modeliser directement : quand un employe change de poste, on modifie son role, et toutes ses permissions se mettent a jour automatiquement. Il garantit aussi la **separation des fonctions** : un agent back-office n'herite jamais des droits AML par construction du systeme.

Limites. RBAC seul est insuffisant : deux conseillers patrimoine ont le meme role mais ne doivent pas voir les memes clients. Il faut un filtrage contextuel en complement.

3.2 ABAC — Attribute-Based Access Control

Principe. La decision d'acces est calculee en temps reel selon des attributs de l'utilisateur, de la ressource et du contexte.

Pourquoi ce modele est necessaire. ABAC repond aux limites de RBAC en ajoutant quatre filtres contextuels :

- **Portefeuille :** le conseiller ne consulte que les clients qui lui sont assignes
- **Pays :** les donnees d'un client sont accessibles uniquement depuis sa juridiction
- **Sensibilite :** un dossier passant de N2 a N4 pendant une enquete declenche automatiquement des controles plus stricts
- **Temporalite :** les acces des experts regionaux sont bornes dans le temps et revoques automatiquement a echeance

Combinaison avec RBAC. RBAC determine d'abord qui est l'utilisateur et quel est son role. ABAC affine ensuite la decision selon le contexte. Les deux modeles sont inseparables dans ce systeme.

3.3 BLP — Bell-LaPadula (confidentialite)

Principe. Deux regles fondamentales s'appliquent a toutes les donnees classifiees :

- **No read up :** un utilisateur ne peut pas lire une donnee de niveau superieur au sien
- **No write down :** un utilisateur ne peut pas copier ou ecrire une donnee vers un niveau inferieur

Pourquoi ce modele est necessaire. BLP garantit que les dossiers AML et investigations (N4) restent **physiquement inaccessibles** aux cadres commerciaux (N2), meme a haute responsabilite. La regle no write down empeche un analyste AML de copier un dossier sensible vers un espace accessible aux conseillers. Ces deux regles repondent directement aux obligations GAFI et ACPR.

Equipe	Peut lire	Peut ecrire	Justification
Back-office (N2)	N1, N2	N1, N2	Pas d'acces aux dossiers strategiques
Analyste risques (N3)	N1, N2, N3	N3 uniquement	No write down vers N2 ou N1
Conformite AML (N4)	N1 a N4	N4 uniquement	Isolation totale des dossiers critiques
Audit interne	N1 a N4	Aucun (lecture seule)	Independance et non-alteration

Table 3: Application de BLP par equipe

3.4 Biba — Modele d'integrite

Principe. Biba est le symetrique de BLP, applique a l'integrite plutot qu'a la confidentialite :

- **No read down :** un utilisateur de haut niveau ne lit pas des donnees de niveau inferieur (pour ne pas contaminer ses analyses)
- **No write up :** un utilisateur de bas niveau ne peut pas modifier des donnees de niveau superieur

Pourquoi ce modele est necessaire. Sans Biba, un agent back-office (N1) pourrait alterer les journaux d'audit (N4). Un expert regional temporaire pourrait modifier les dossiers permanents de la banque. Biba interdit ces scenarios en protégeant l'integrite des donnees critiques, independamment de la confidentialite.

Complementarite avec BLP. BLP protege la confidentialite (qui peut lire quoi). Biba protege l'integrite (qui peut modifier quoi). Les deux modeles s'appliquent simultanement : un meme acces doit passer les deux filtres.

3.5 Chinese Wall — Brewer-Nash (conflits d'interet)

Principe. Les barrieres d'acces sont **dynamiques** et evoluent selon l'historique des consultations. Une fois qu'un utilisateur a accede aux donnees d'une entite, il est automatiquement bloque sur les donnees des entites conflictuelles.

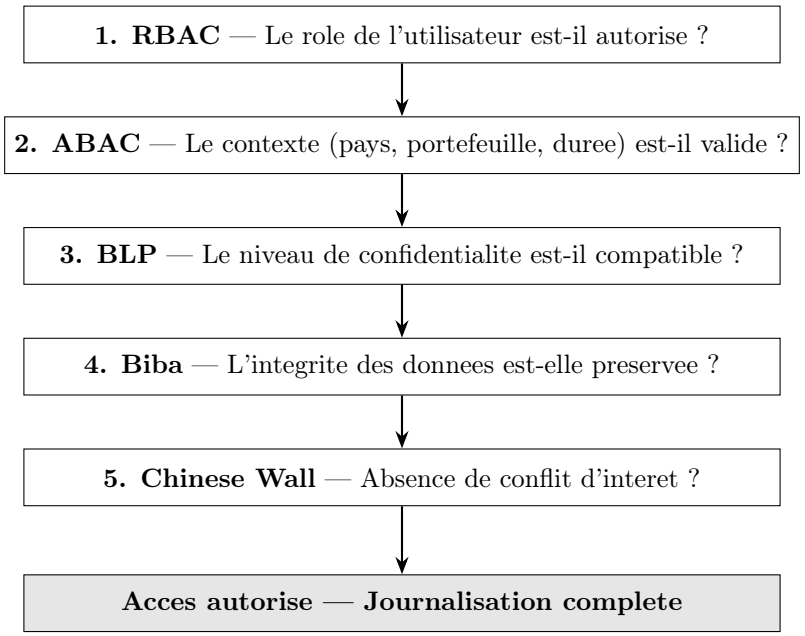
Pourquoi ce modele est necessaire. C'est le seul modele specifiquement concu pour le secteur financier. Il couvre deux risques critiques que RBAC et ABAC ne peuvent pas gerer :

- **Delit d'initie :** un analyste risque ayant consulte le dossier de l'entreprise A est automatiquement bloque sur les donnees de ses concurrents directs
- **Conflit juridique :** un juriste implique dans un contentieux ne peut pas acceder aux donnees de la contrepartie adverse

Particularite. Contrairement aux autres modeles, Chinese Wall n'est pas defini a priori — les restrictions se construisent en temps reel selon ce que l'utilisateur a deja consulte. C'est le modele le plus dynamique du systeme.

4. Architecture en couches

Les cinq modeles s'appliquent en sequence. Un acces n'est accorde que si toutes les couches le valident simultanement.



A chaque etape, un echec entraine un refus immediat, une alerte securite et une entree dans le journal d'audit.

5. Niveaux de securite

Niv.	Designation	Donnees	Controles
N1	Interne metier	Operations courantes, referentiels	Authentification standard
N2	Sensible	Donnees clients, contrats, historiques	Auth. + journalisation
N3	Tres sensible	KYC detaille, risque strategique	MFA + justification metier
N4	Critique	AML, sanctions, investigations	MFA + double validation + isolation

Table 4: Classification des donnees et controles associes

La progression est non lineaire : passer de N3 a N4 implique non seulement des controles techniques supplementaires, mais aussi une isolation organisationnelle complete via BLP et Chinese Wall.

6. Division en equipes et effectifs

Perimetre : banque internationale, 500 employes, presence multi-pays, activites de detail, patrimoine et conformite reglementaire.

Base de dimensionnement : ratio ACPR de 1 agent de controle pour 8 operationnels ; norme IIA de 1 auditeur pour 25 employes en contexte bancaire complexe ; standard GAFI de 1 analyste AML pour 15 millions d'euros de transactions surveillees.

6.1 Relation clientele — 120 agents (24%)

Role. Premier point de contact avec les clients particuliers et entreprises. Les conseillers ouvrent les comptes, traitent les demandes courantes, collectent les informations KYC de base et orientent les clients vers les metiers specialises.

Justification de l'effectif. Le ratio standard dans la banque de detail est de 1 conseiller pour 80 a 120 clients actifs (reference BNP Paribas Retail, Societe Generale reseaux). Avec une base clientele de 10 000 clients actifs, 120 conseillers est le minimum operationnel. En dessous, les delais de traitement augmentent et la qualite du KYC se degrade, ce qui expose la banque a un risque reglementaire direct.

Modeles appliques. RBAC attribue le role *conseiller* avec acces N1–N2 uniquement. ABAC filtre par portefeuille assigne : un conseiller de Tunis ne peut pas consulter les clients d'un collegue de Paris, meme s'ils ont le meme role. Ce filtre est essentiel car la reglementation locale (droit tunisien, RGPD europeen) s'applique differemment selon le pays du client.

Restrictions cles. Acces interdit aux analyses de risque strategique, aux dossiers KYC approfondis et a tout element de niveau N3 ou N4. BLP bloque tout acces vers le haut par construction.

6.2 Back-office — 80 agents (16%)

Role. Le back-office est le moteur operationnel invisible de la banque. Il traite les virements, rapprochements comptables, ordres de marche et corrections d'anomalies administratives. Sans back-office operationnel, aucune transaction ne peut etre finalisee.

Justification de l'effectif. Le ratio standard dans les banques internationales est de 1 agent back-office pour 6 a 8 conseillers front (reference operations SWIFT T2S, rapport BCE 2022 sur les

infrastructures de paiement). Avec 120 conseillers en front, 80 agents BO est le dimensionnement minimal pour absorber les pics de volume en fin de journee et en periode de cloture mensuelle.

Modeles appliques. RBAC limite les droits au perimetre operationnel N1–N2. Biba est le modele critique pour cette equipe : la regle *no write up* interdit formellement a un agent BO de modifier un dossier de niveau N3 ou N4. Sans cette regle, un agent malveillant ou involontairement distrait pourrait alterer un rapport de risque ou un journal d'audit, ce qui constituerait une violation grave des obligations prudentielles.

Restrictions cles. Double validation obligatoire au-dela de 50 000 euros. Aucun acces aux analyses de risque, aux dossiers KYC avances ni aux investigations en cours.

6.3 Gestion de patrimoine — 60 conseillers (12%)

Role. Les conseillers patrimoniaux gerent des clients a haute valeur nette (High Net Worth Individuals). Ils ont acces aux donnees financieres detaillees : compositions de portefeuille, ordres de marche, strategies d'investissement, credits immobiliers et structurations fiscales.

Justification de l'effectif. Le ratio dans la banque privee est de 1 conseiller pour 30 a 50 clients patrimoniaux (standard Credit Suisse Private Banking, rapport KPMG Wealth Management 2023). Ces clients exigent un suivi personnalise intensif, ce qui justifie un ratio bien plus serre que la banque de detail. 60 conseillers pour une base de 2 000 clients patrimoniaux est conforme aux pratiques du secteur.

Modeles appliques. ABAC est le modele central : le filtre par portefeuille assigne est absolu. Deux conseillers patrimoniaux ont exactement le meme role RBAC mais ne peuvent jamais consulter les clients l'un de l'autre. Chinese Wall s'applique egalement : un conseiller ayant travaille sur la structuration d'un groupe industriel est automatiquement bloque sur les donnees des concurrents de ce groupe, pour prevenir tout delit d'initie.

Restrictions cles. Acces strictement limite aux clients du portefeuille assigne. BLP bloque l'acces aux dossiers AML meme si un client patrimoinial fait l'objet d'une enquete — dans ce cas, le dossier est transfere a la conformite et le conseiller perd l'acces.

6.4 Risque — 40 analystes (8%)

Role. L'equipe risque surveille les expositions de la banque : risque de credit (defaut des emprunteurs), risque de marche (fluctuations des actifs), et risque operationnel (defaillances internes). Elle produit les reportings prudentiels exiges par Bale III/IV et alerte la direction en cas de depassement de seuils.

Justification de l'effectif. La norme Bale III impose une couverture exhaustive du portefeuille de risques. Le ratio operationnel est de 1 analyste pour 12 a 15 millions d'euros d'encours surveilles (reference rapport EBA 2023 sur les modeles internes). Le profil est tres qualifie (masters quantitatifs, certifications FRM/CFA), ce qui explique un effectif volontairement maîtrise a 40 personnes malgre un perimetre de couverture large.

Modeles appliques. BLP est essentiel : les analystes risque ont besoin de consulter des donnees multi-clients pour leurs modeles, mais ils ne doivent jamais modifier ces donnees (acces en lecture seule strict). Chinese Wall intervient sur les decisions d'investissement : un analyste ayant evalue le risque de credit de l'entreprise A est bloque sur les informations confidentielles de ses concurrents directs.

Restrictions cles. Acces en lecture seule sur les contrats de credit et donnees clients. Aucun acces aux dossiers AML actifs, qui pourraient biaiser les modeles de risque ou creer des conflits d'interet avec les investigations en cours.

6.5 Conformite / AML — 35 agents (7%)

Role. C'est l'equipe la plus sensible du systeme. Elle traite les alertes de blanchiment d'argent, surveille les transactions suspectes, gere les dossiers KYC approfondis, applique les sanctions internationales

(listes OFAC, ONU, UE) et transmet les declarations de soupcon aux autorites (TRACFIN en France, équivalents locaux).

Justification de l'effectif. Le standard GAFI recommande 1 analyste AML pour 15 millions d'euros de volume transactionnel surveille. Les amendes infligees aux banques pour defaillances AML sont colossales : HSBC (1,9 milliard USD en 2012), BNP Paribas (8,9 milliards USD en 2014), Deutsche Bank (630 millions USD en 2017). Un sous-dimensionnement de cette equipe est donc un risque financier et reputationnel majeur, pas seulement reglementaire.

Modeles appliques. Les cinq modeles s'appliquent simultanement a cette equipe. RBAC lui donne acces N3–N4. ABAC filtre par dossier actif : un analyste AML n'accede qu'aux dossiers qui lui sont affectes, pas a l'ensemble des enquetes en cours. BLP garantit que les dossiers N4 ne peuvent pas etre copies vers des espaces moins securises. Biba protege l'integrite des preuves collectees. Chinese Wall isole les enquetes des activites commerciales.

Restrictions cles. Les dossiers AML actifs sont **physiquement inaccessibles** aux cadres commerciaux, y compris aux directeurs generaux adjoints. Cette regle est non negociable : elle est inscrite dans la directive europeenne AMLD6 et dans les recommandations GAFI. Toute consultation requiert MFA et double validation.

6.6 Audit interne — 20 auditeurs (4%)

Role. L'audit interne est le garant independant de l'efficacite du systeme de controle. Il verifie que les acces sont correctement attribues, que les journaux d'audit sont complets et fiables, et produit des rapports pour le conseil d'administration et les regulateurs.

Justification de l'effectif. La norme IIA (Institute of Internal Auditors) recommande un ratio de 1 auditeur pour 25 a 50 employes selon la complexite. Dans une banque internationale soumise a de multiples regulateurs (ACPR, BCE, Fed pour les activites US, MAS pour l'Asie), le ratio est resserre a 1/25, soit 20 auditeurs pour 500 employes. Ce dimensionnement correspond aux pratiques de Societe Generale et Credit Agricole pour leurs entites de taille comparable.

Modeles appliques. BLP en mode lecture seule absolue : l'audit peut tout lire (N1 a N4) mais ne peut rien modifier. C'est une exigence d'independance fondamentale — un auditeur qui peut modifier les journaux qu'il controle invalide l'integrite de tout le dispositif. Biba renforce cette regle : la regle *no write up* empeche toute alteration des donnees de niveau superieur.

Restrictions cles. Acces en lecture seule uniquement, sans exception. L'equipe d'audit doit etre organisationnellement independante de toute ligne metier. Ses acces aux dossiers actifs N4 sont bornes dans le temps et traces dans un journal separe.

6.7 Juridique — 20 juristes (4%)

Role. L'equipe juridique intervient sur trois fronts : la validation des operations complexes (emissions obligataires, fusions-acquisitions, credits syndicaux), la gestion des contentieux avec les clients ou contreparties, et les echanges avec les autorites de regulation (reponses aux injonctions, transmissions de documents).

Justification de l'effectif. La presence internationale implique la maitrise du droit local de chaque juridiction : droit tunisien, droit francais, droit anglais (common law), regulations americaines (Dodd-Frank). Le ratio standard dans les banques de taille comparable est de 1 juriste pour 25 millions d'euros d'actifs sous gestion (reference etude Linklaters 2022 sur les equipes juridiques bancaires). 20 juristes est le minimum pour couvrir les principaux territoires d'implantation.

Modeles appliques. BLP garantit que le juriste n'accede qu'aux dossiers relevant de son perimetre de competence. Chinese Wall est particulierement critique ici : un juriste implique dans la defense de la banque dans un litige ne peut pas acceder aux donnees de la contrepartie adverse, ce qui serait une violation grave de la deontologie professionnelle et potentiellement du secret professionnel.

Restrictions cles. Acces limite aux seuls dossiers litigieux actifs affectes. Journalisation complete de toutes les consultations de dossiers sensibles, exigee par les barreaux locaux et les regulateurs.

6.8 Cadres commerciaux — 25 cadres (5%)

Role. Les directeurs commerciaux et responsables de segment pilotent la performance commerciale de la banque. Ils analysent les KPIs de production, fixent les objectifs des equipes, valident les operations hors norme et representent la banque aupres des grands comptes.

Justification de l'effectif. Le ratio standard d'encadrement dans les organisations bancaires est de 1 cadre pour 15 a 20 collaborateurs (reference Hay Group Banking Survey 2022). Avec 300 agents operationnels, 25 cadres representent un taux d'encadrement de 1/12, legerement superieur a la norme, justifie par la complexite multi-pays.

Modeles appliques. RBAC plafonne leur acces a N2 : les cadres commerciaux ont une vision agregee des performances mais pas acces aux dossiers individuels sensibles. BLP est la regle la plus importante pour cette equipe : elle garantit que meme un directeur regional ne peut jamais lire un dossier AML N4, quelle que soit sa hierarchie. Cette separation est une exigence de la directive AMLD6 : la pression commerciale ne doit jamais influencer une enquete de blanchiment.

Restrictions cles. Isolation totale et incontournable des dossiers AML, sanctions et investigations. Acces aux donnees clients uniquement sous forme agregee et anonymisee pour le reporting.

6.9 Experts regionaux temporaires — pool de 10

Role. Ces experts sont mobilises ponctuellement pour des investigations necessitant une connaissance locale approfondie : reglementation fiscale d'un pays specifique, pratiques commerciales d'un secteur, expertise sur un instrument financier particulier. Ils ne sont pas employes permanents.

Justification de l'effectif. Le pool de 10 experts couvre les principales zones d'implantation de la banque. Le nombre d'experts actifs simultanement est typiquement de 2 a 3. Ce modele de *surge capacity* est utilise par les grandes banques (Barclays, Standard Chartered) pour les enquetes reglementaires ponctuelles sans surcharger les effectifs permanents.

Modeles appliques. ABAC est le modele central et le plus critique pour cette equipe. L'attribut de temporalite definit exactement la duree d'acces (exemple : 30 jours pour une investigation precise), le perimetre (uniquement les documents du dossier affecte) et le pays (acces limite a la juridiction concernee). A l'echeance, l'acces est revoque automatiquement sans aucune intervention humaine. Biba interdit toute modification des dossiers permanents : l'expert peut lire et annoter, mais ne peut pas alterer les donnees source.

Restrictions cles. Perimetre d'acces defini contractuellement avant l'ouverture. Revocation automatique a echeance. Traçabilite renforcee sur l'ensemble de la periode d'acces. Aucun acces possible apres revocation, meme en cas de demande urgente — une nouvelle procedure d'autorisation doit etre ouverte.

6.10 Recapitulatif des effectifs

Equipe	Effectif	Part	Modeles prioritaires
Relation clientele	120	24%	RBAC, ABAC (portefeuille, pays)
Back-office	80	16%	RBAC, Biba
Gestion patrimoine	60	12%	ABAC, Chinese Wall
Risque	40	8%	BLP (lecture), Chinese Wall
Conformite / AML	35	7%	BLP + Biba + CW, isolation N4
Audit interne	20	4%	BLP (lecture seule absolue)
Juridique	20	4%	BLP, Chinese Wall
Cadres commerciaux	25	5%	RBAC N2, BLP bloque N4
Experts regionaux	≈10	2%	ABAC temporalite, Biba
Fonctions support	90	18%	RBAC, ABAC base
Total	**500**	**100%**	

Table 5: Effectifs et modeles prioritaires par equipe

7. Regles transverses

Independamment des modeles, trois regles s'appliquent a tout le systeme :

1. **Journalisation complete.** Toute consultation ou modification d'une ressource N2 ou superieure est enregistree avec horodatage, identifiant utilisateur et justification.
2. **Double validation.** Les operations financieres depassant 50 000 EUR et toute modification de dossier N3–N4 requierent l'approbation d'un second agent habilite.
3. **Revocation automatique.** Les acces temporaires (experts regionaux) sont revoques automatiquement a echeance sans intervention manuelle.

8. Conclusion

Le systeme de controle d'acces propose repose sur la complementarite de cinq modeles :

- **RBAC** structure les permissions par role metier
- **ABAC** affine les decisions selon le contexte en temps reel
- **BLP** garantit l'isolation absolue des dossiers les plus sensibles
- **Biba** protege l'integrite des donnees critiques contre toute alteration
- **Chinese Wall** previent dynamiquement les conflits d'interet

Le point le plus critique du dispositif est l'**isolation des dossiers AML et sanctions** vis-a-vis des equipes commerciales. BLP assure que cette isolation est technique et incontournable — aucune modification de role ou pression hierarchique ne peut la contourner. C'est cette garantie qui satisfait les obligations reglementaires GAFI, ACPR et les exigences Bale III/IV.